AIエージェント 本番前チェックリスト

AIエージェント・ボット・定期ジョブに、人が見ていない状態で「書き込み」（投稿・デプロイ・メール送信・支払い）をさせる前に確認する25項目です。

v1.0 — NeuralAlpha — qiita.com/NeuralAlphaAI ／ zenn.dev/neuralalpha

1. なりすまし防止：正しいアカウントで動いているか

- ☐ 最初の書き込みの前に「自分は誰か」を確認している（APIの「認証中のユーザー」を取得し、コードに直書きしたアカウント名・IDと照合する）。
- ☐ 一致しなければ止まる。警告を出して続行はしない。
- ☐ アカウントごとに認証情報のファイルを分け、1つのジョブが2つ以上の認証情報を読み込まない。
- ☐ そのジョブが書き込めるアカウントを、すべて言える。

2. 待機状態：止めたつもりのジョブが動かないか

- ☐ 「本番」と「ドライラン（送信しない）」の切り替えが1か所にあり、初期値はドライラン。
- ☐ 古いスケジューラ・バッチファイル・cron を調べ、本番投稿できる状態のまま残っているジョブがないか確認した。古いパイプラインは勝手には止まらない。
- ☐ 「止めた」ことが目に見える変更になっている（フラグを外す、コメントアウトする、日付付きのバックアップを残す）。

3. 書き込み：2回目の送信で何が起きるか

- ☐ 送信の前に「試行（attempt）」を記録し、送信後に 成功／失敗／不明 のどれかを記録している。
- ☐ 「不明」（タイムアウト・接続切れ）が残っている間は、人が確認するまで次の送信をしない。自動リトライはしない。再送された投稿や決済はただの重複になる。
- ☐ 送る項目ごとに固定のIDがあり、送信済みかどうかを判定できる。
- ☐ HTTP 200 は「確認」ではなく「主張」として扱う。大事な書き込みは、作ったものを読み返して確かめる。

4. 上限：最悪の1日はどうなるか

- ☐ 1日あたりの上限（投稿数・メール数・API呼び出し数）があり、プロンプトではなくコードが強制している。
- ☐ 費用の上限を、コードだけでなくプロバイダーの管理画面でも設定している。
- ☐ 呼び出しごとの費用を記録し、残高が尽きる前に警告が来る。
- ☐ 書き込みどうしの最小間隔をコードが強制している。

5. 内容：何を言ってよいか

- ☐ 文字数・リンク・禁止語は、送信前にコードでチェックしている。
- ☐ エージェントが絶対に扱わない話題（助言・断定・約束など）を文書にしている。
- ☐ エージェントが語ってよい「実話」は、ログ・コミット・領収書などの根拠があるものだけ。

6. 納品物：お客さんに実際に届くものは何か

- ☐ 自分の商品を、本番と同じ購入手続き（テストモード）で買い、ファイルを開いて確かめた。
- ☐ 届いたファイルの SHA-256 が、出荷するつもりのビルドと一致している。
- ☐ アーカイブに社内メモ・ローンチ計画・鍵・他のお客さんのデータが入っていない。
- ☐ ビルドが再現可能（作り直しても同じハッシュになる）。

7. 実行環境：夜中に止まらないか

- ☐ 本番と同じスケジューラ・ユーザー・ロケール・文字コードで一度動かした。Windows の cp932 と UTF-8 の違いは、夜中に止まる典型的な原因。
- ☐ 失敗がログファイルだけでなく、人に届く。
- ☐ エージェント以外の誰かが、毎日その日の要約を読んでいる。

判断の目安： ひとつでも「いいえ」があれば、「はい」になるまでドライランで動かす。

どの項目も、小さな自動運用で実際に起きた（または起きかけた）ことから作りました。項目を強制するPythonのコード（記録帳・緊急停止・上限・死活監視など）は「Agent Ops Guardrails Kit」にまとめています：
neuralalpha.gumroad.com/l/agent-ops-guardrails-kit

投資・法律・セキュリティの助言ではありません。ご自身の環境に合わせて調整してください。